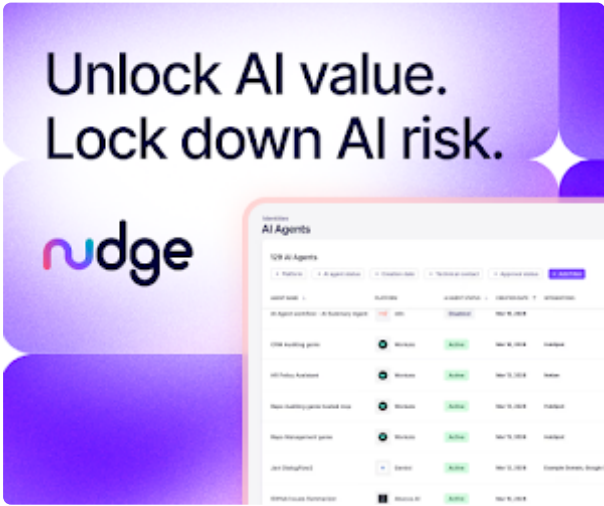
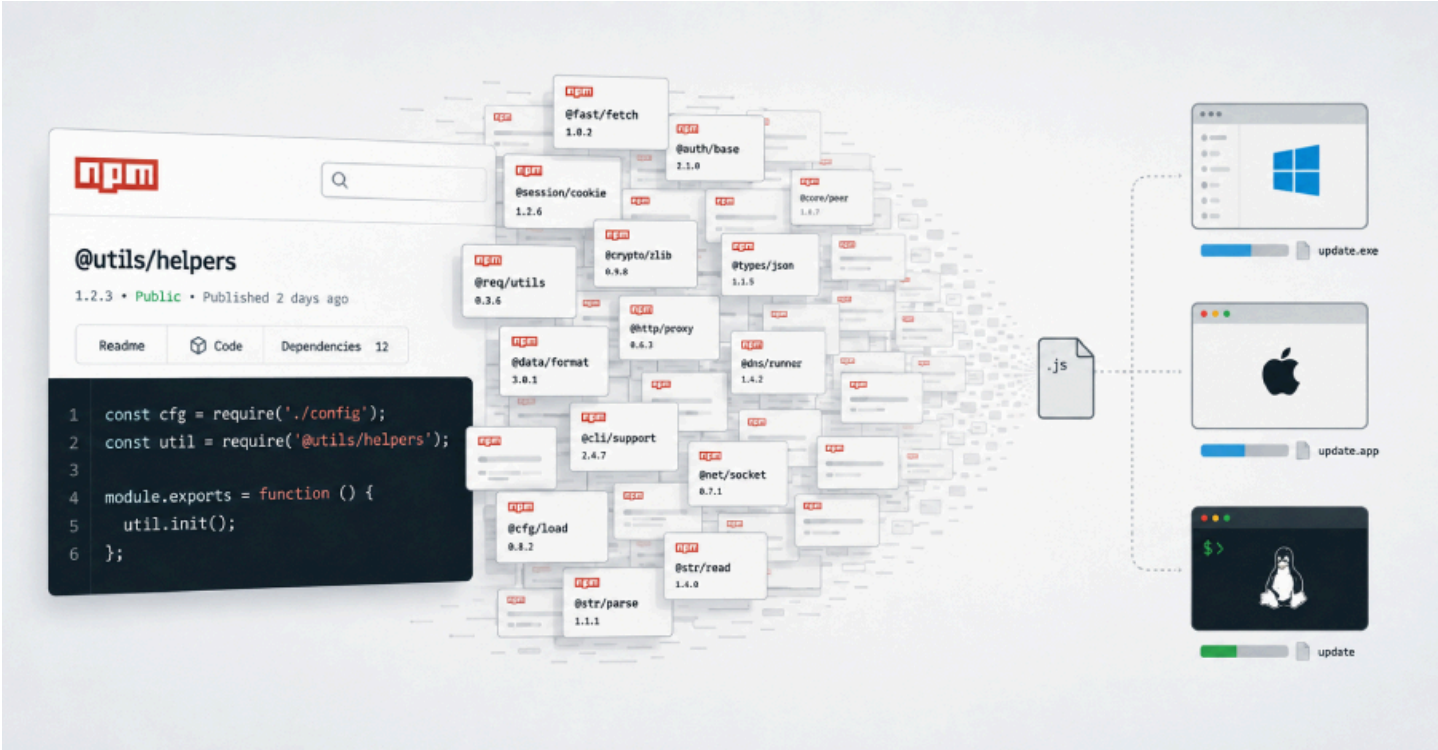




Почти 800 вредоносных пакетов npm содержат кроссплатформенные программы-шпионы и программы для кражи данных

👤 Рави Лакшманан 📅 7 августа 2026 года



В реестр nrm был опубликован кластер из почти 800 вредоносных пакетов в рамках новой кампании по распространению кроссплатформенного вредоносного ПО, нацеленного на системы Windows, Mac и Linux.

«Судя по всему, в этих пакетах используются имена пакетов, сгенерированные искусственным интеллектом, или случайно сгенерированные имена пакетов с опечатками, но все они содержат мощный RAT и программу для кражи данных», — **сказал** исследователь OpenSourceMalware Пол Маккарти.

В отличие от других атак на цепочки поставок программного обеспечения, ориентированных на nrm, в которых используются хуки жизненного цикла, такие как preinstall или postinstall, для запуска вредоносного кода, новые обнаруженные пакеты содержат файл README, в котором разработчикам предлагается загружать их с помощью require() — встроенной функции для импорта модулей, локальных файлов и сторонних пакетов.

Атака приводит к запуску загрузчика под названием **WEL1DROPPER**, который при запуске определяет операционную систему и архитектуру процессора хоста и загружает совместимую полезную нагрузку с одного из трех хостов Cloudflare Workers. Ниже перечислены три домена Cloudflare Workers:

- oob-worker.cf103-070.workers[.]dev
- oob-worker.cf102-baf.workers[.]dev
- oob-worker.cf99-9b3.workers[.]dev



Если загрузка по протоколу HTTPS не удалась, вредоносное ПО переключается на домен, специфичный для конкретной платформы, и использует DNS-записи TXT для перехода на следующий этап с домена wel1[.]ru. Домен полезной нагрузки для каждой операционной системы и архитектуры процессора выглядит следующим образом:

- Linux x64 — `sdk.dl.wel1[.]ru`
- Linux ARM64 — `ext.dl.wel1[.]ru`
- macOS — `pkg.dl.wel1[.]ru`
- Windows — `net.dl.wel1[.]ru`

«Сначала пакет запрашивает TXT-запись с сервера `c.<domain>`, — объяснил Маккарти. — Он анализирует ответ на предмет количества фрагментов полезной нагрузки, принимая значение от 1 до 2000. Затем он запрашивает пронумерованные TXT-записи. Возвращенные строки объединяются и декодируются в двоичный буфер в формате Base64».

На последнем этапе полезная нагрузка записывается во временную папку и выполняется либо с помощью `/bin/sh` в Linux и macOS, либо с помощью `cmd.exe` в Windows.

Компания Sonatype, которая также **отслеживает** эту кампанию под названием Flooding Dropper, сообщила, что финальный этап запускается как отдельный процесс. Версия для Windows вносит изменения в Event Tracing for Windows (ETW) и Antimalware Scan Interface (AMSI), чтобы помешать мониторингу, проверяет наличие «песочниц» и виртуальных сред, обеспечивает постоянную активность с помощью ключа реестра Run и запланированной задачи, а также загружает зашифрованную полезную нагрузку (`"/pkg/update_win.exe"`) и запускает ее.

Цепочка заражения macOS аналогична: она выполняет идентичный набор действий для поиска отладчиков и артефактов анализа, прежде чем загрузить совместимую полезную нагрузку (`"/pkg/beacon_mac.bin"`) с удаленного сервера. Если это не удастся, используется вышеупомянутый метод доставки через DNS TXT, настраивается постоянное присутствие с помощью LaunchAgent, а затем запускается исполняемый файл в отдельном процессе.

С другой стороны, образец для Linux представляет собой **упакованный UPX** двоичный файл ELF, который настроен на загрузку вспомогательных полезных нагрузок с URL-адреса Cloudflare Worker (`"oob-worker[.]cf99-9b3.workers[.]dev"`), что в конечном итоге приводит к развертыванию **Sliver**, фреймворка с открытым исходным кодом для управления и контроля (C2).

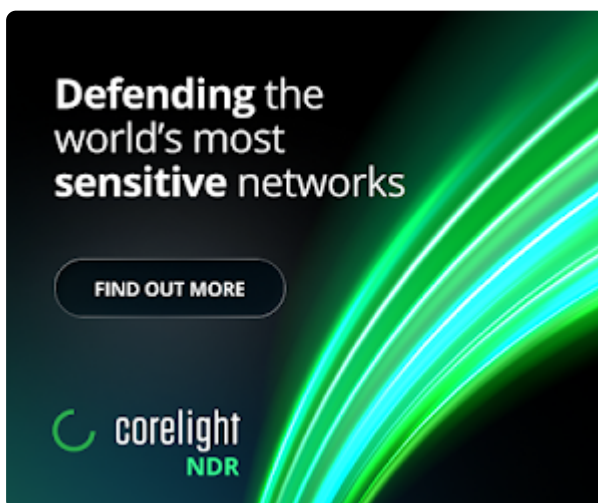
The packages have also been found to contain a file called `"lib/telemetry.js"` that implements a plausible-looking telemetry SDK but also contains the same downloader logic.

"The package entry point does not import this file, and it contains no additional hard-coded infrastructure," OpenSourceMalware said. "The oversized telemetry implementation appears intended

to add noise and make the malicious behavior look like native profiling or analytics functionality during a quick review."

The presence of domains like "tcsbank[.]ru" and "cloudpayments[.]ru" in the macOS payload indicates that the campaign could be targeting Russian financial institutions and mobile payments.

It's also suspected to be an evolution of a [dependency confusion](#) campaign codenamed **Moika** that was observed earlier this April and saw over 250 packages published to the npm registry to steal environment information and deliver an operating system-specific second-stage payload.



The development comes as Palo Alto Networks Unit 42 documented multiple campaigns targeting npm and the Python Package Index (PyPI) repository -

- A set of [10 npm packages](#) that download an obfuscated cryptocurrency stealer and a remote access trojan from an external server. "After installation, the packages export a 'getPlugin' function that constructs the URL from which the payload is downloaded as an obfuscated IIFE (Immediately Invoked Function Expression) JavaScript code embedded in a JSON object," Unit 42 said. "The payload implements a crypto stealer and Remote-Access Trojan (RAT) that allows the attacker to execute arbitrary commands on the infected host."
- A set of [malicious packages across npm and PyPI](#) representing multiple distinct threat actors that are capable of cloud credential exfiltration, delivering EtherHiding blockchain-based C2 droppers, Solana cryptocurrency wallet key theft via Telegram, .env file secret exfiltration, fake-CAPTCHA social engineering remote code execution, and Discord token theft and GitHub Actions CI/CD credential exfiltration.

From Packages to Chrome Extensions

Threat actors have also been observed using Google Chrome extensions marketed as game emulators, password managers, productivity tools, CSS inspectors, and markdown converters to turn the web browser into a web crawling proxy. The crawl commands are received remotely via a persistent WebSocket connection.

"These extensions embed an identical commercial web bandwidth-sharing SDK that connects the user's browser to a 3rd party residential proxy network for web scraping operations," Unit 42 [said](#), adding it crawls pages by injecting a hidden iframe into active browser tabs, converts page content to Markdown in the background, and sends it to a remote cloud backend.

The cybersecurity company noted that some of these extensions disclose the practice in their Chrome Web Store descriptions and in the privacy policies on their SaaS websites. Once installed, the third-party SDK prompts users to opt-in to the service.

"While the proxy and crawling features remain inactive if the user declines, some extensions frame this opt-in as necessary for uninterrupted service," Unit 42 said. "A notable example is InstaSkip (mdondgockboebafluibbhjofmoedmnnn), which embeds this SDK."

Found this article interesting? Follow us on [Google News](#), [Twitter](#) and [LinkedIn](#) to read more exclusive content we post.

 | [Tweet](#)  | [Share](#)  | [Share](#)

Get the Latest News in Your Inbox

Get the latest news, expert insights, exclusive resources, and strategies from industry leaders, all for free.

Your e-mail address

CYBERSECURITY WEBINARS

[Risk in AI-Generated Code](#)

How to Secure AI Code Before It Reaches Production

Learn how 300 enterprise leaders are managing AI-driven open-source risk, remediation debt, and governance at scale.

[Attend Live](#)

Build AI Securely

How to Secure AI-Built Software at Machine Speed

Learn how to govern risk, secure AI-built software, and keep control as development moves at machine speed.

[Watch Free Now](#)

⚡ Latest News

Cybersecurity Resources



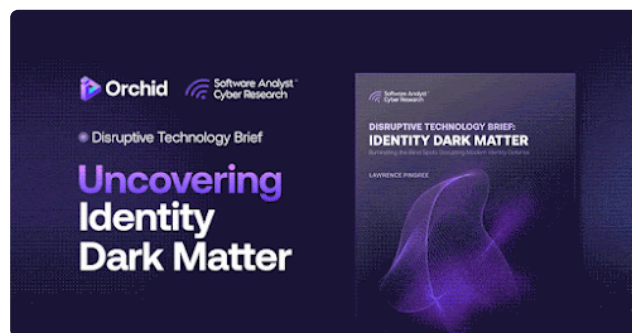
Burp, sqlmap, SSRF, XXE, SSTI: Web Exploitation, Hands-On



SANS AI Cybersecurity Summit Returns This November



11 Real Stories: How Identity Exposure Unlocks Active Attack Paths



Uncover Identity Dark Matter: SACR Research Brief

Expert Insights

[Videos](#)

[Articles](#)

Rahul Madduluri

CTO and Co-Founder

 Doppel



The Blind Spot in Modern Email Security

Alon Biran

VP of Product Management

 Island



Agents Work Everywhere Now. Governance Has to See Everywhere Too.

Ido Shlomo

CTO & Cofounder

 token



AI Agent Lifecycle Risks

Austin O'Saben

Product Marketing Manager

 Kaseya®



How AI-Assisted Attacks Are Breaking Legacy SIEM Tools

Connect with us!



Company

[About THN](#)

[Advertise with us](#)

[Contact](#)



[Contact Us](#)

Pages

[Webinars](#)

[Awards](#)

[Privacy Policy](#)